

SIMATS ENGINEERING ASSESSMENT TOOL 2

Name	SHAIK REEHAN
Register Number	192565071
Date	
Time	1hr

COURSE NAME: CYBERSECURITY INCIDENT HANDLING AND RESPONSE
COURSE CODE: CSA60

COURSE OUTCOME COVERED

CO1: Apply the concepts of cybersecurity incidents by distinguishing security events from incidents, implementing incident handling lifecycle stages, frameworks, with documentation practices in organizational contexts. (BL1, BL2)

Activity Tool : Incident Response Lifecycle Mapping (NIST/ISO 27035) (Medium)
 Assessment Tool Weightage: 20%

Code of Conduct:

*I _____ shaikreehan _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
 I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Incident Response Lifecycle Mapping	30%	Correctly maps all lifecycle phases (Preparation, Detection & Analysis, Containment, Eradication,	Maps most lifecycle phases correctly with minor	Includes only some lifecycle phases with noticeable	Fails to identify or sequence the lifecycle

		Recovery, Lessons Learned) in the proper sequence with no omissions.	sequencing or content errors.	omissions or incorrect sequencing.	phases correctly.
Application of NIST/ISO 27035 Framework	25%	Accurately applies the selected framework using appropriate terminology and activities throughout the response.	Applies the framework correctly with minor inaccuracies in terminology or activities.	Demonstrates partial understanding of the framework with several errors or omissions.	Incorrect or minimal application of the selected framework.
Reactive vs. Proactive Classification	20%	Correctly distinguishes all response activities as Reactive or Proactive with clear justification.	Correctly classifies most activities with minor errors or incomplete justification.	Partially correct classification with several misclassifications.	Incorrect or missing classification of Reactive and Proactive activities.
Flowchart Organization and Logical Representation	15%	Flowchart is well-organized, logically structured, easy to follow, and professionally presented using appropriate symbols.	Flowchart is organized with minor layout or sequencing issues.	Flowchart is partially organized but difficult to follow in some sections.	Flowchart is incomplete, poorly organized, or difficult to interpret.
Explanation and Technical Clarity	10%	Provides clear, concise, and technically accurate explanations supporting the incident response workflow.	Explanation is generally clear with minor technical or language errors.	Explanation is understandable but lacks clarity or technical accuracy.	Explanation is incomplete, unclear, or technically incorrect.

Criteria	Incident Response Lifecycle Mapping (4)	Application of NIST/ISO 27035 Framework (4)	Reactive vs. Proactive Classification (4)	Flowchart Organization and Logical Representation (4)	Explanation and Technical Clarity (4)	TOTAL (20)
Weightage	30%	25%	20%	15%	10%	100%
Q1						
Q2						
Q3						
Q4						
Q5						

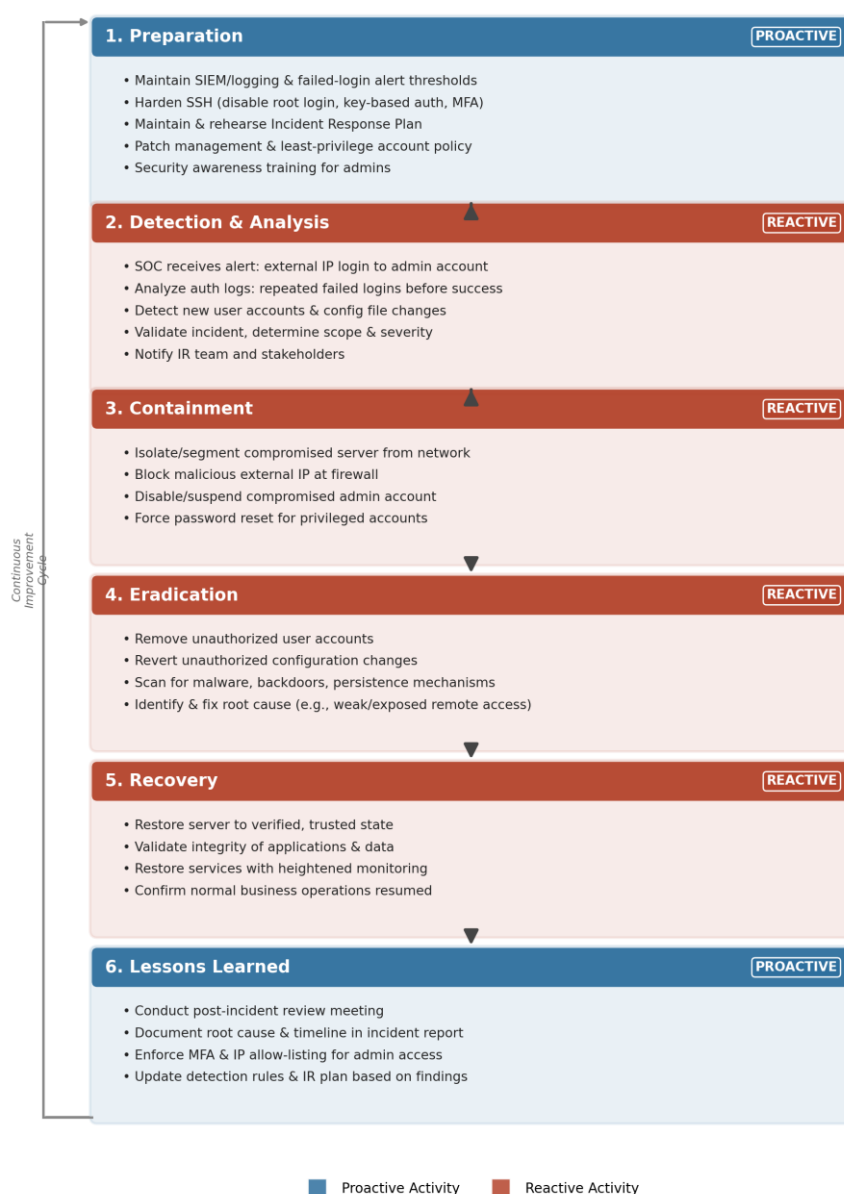
1. Unauthorized Remote Access

Scenario Summary

An organization's Security Operations Center (SOC) receives an alert indicating that an external IP address has successfully logged in to a Linux production server using an administrator account. Authentication logs reveal multiple failed login attempts before the successful login, followed by the unauthorized creation of new user accounts and modification of system configuration files. The server hosts critical business applications used by customers, making rapid, structured incident response essential to limit business impact and protect customer trust.

Incident Response Lifecycle Flowchart (NIST SP 800-61 Rev.2)

Incident Response Lifecycle - Unauthorized Remote Access (NIST SP 800-61 Rev.2)



Detailed Phase-wise Activities and Classification

IR Phase	Classification	Activities Performed
Preparation	Proactive	• Maintain SIEM/log monitoring with alerting thresholds for repeated failed logins • Harden SSH access: disable root login, enforce key-based authentication and MFA • Maintain and regularly rehearse an Incident Response Plan and escalation matrix • Enforce patch management, least-privilege access, and account review policies • Conduct security awareness training for system administrators
Detection & Analysis	Reactive	• SOC receives alert of a successful login from an external/unrecognized IP address • Analyze authentication logs; identify a pattern of multiple failed attempts before success (indicative of brute-force) • Detect unauthorized creation of new user accounts and modification of system configuration files • Validate the alert as a true incident, determine scope, affected assets, and severity • Notify the Incident Response team and relevant stakeholders per the IR plan
Containment	Reactive	• Short-term: isolate the compromised Linux server from the production network/segment • Block the malicious external IP address at the perimeter firewall • Disable or suspend the compromised administrator account • Long-term: force password resets for all privileged accounts and restrict remote access
Eradication	Reactive	• Remove the unauthorized user accounts created by the attacker • Revert unauthorized changes made to system configuration files • Scan the server for malware, web shells, or persistence mechanisms (e.g., cron jobs, SSH keys) • Identify and remediate the root cause (e.g., exposed SSH port, weak/reused password)
Recovery	Reactive	• Restore the server to a verified, trusted operational state • Validate the integrity of business applications and customer data • Bring services back online gradually under heightened monitoring

IR Phase	Classification	Activities Performed
		• Confirm normal business operations have resumed without residual compromise
Lessons Learned	Proactive	• Conduct a post-incident review meeting with all involved teams • Document root cause, timeline, and response effectiveness in a formal incident report • Enforce MFA, IP allow-listing, and account lockout policies for administrative access • Update detection rules, alert thresholds, and the IR plan based on findings

2. SQL Injection Attack

Scenario Summary

A university's online student portal begins displaying unexpected database errors. Investigation reveals that attackers exploited an SQL Injection vulnerability to retrieve confidential student records. The security team temporarily disables the application, blocks malicious requests through the firewall, restores the database from backups, and patches the vulnerable application. This scenario illustrates a classic application-layer attack requiring both technical remediation and compliance-driven follow-up due to the exposure of personal student data.

Incident Response Lifecycle Flowchart (NIST SP 800-61 Rev.2)

Incident Response Lifecycle - SQL Injection Attack (NIST SP 800-61 Rev.2)



Detailed Phase-wise Activities and Classification

IR Phase	Classification	Activities Performed
Preparation	Proactive	- Establish secure coding standards and provide developer training on input validation - Deploy a Web Application Firewall (WAF) in front of the student portal - Conduct regular vulnerability scanning and penetration testing of web applications - Maintain routine, verified database backups and an IR plan covering web application incidents
Detection & Analysis	Reactive	- Unexpected database errors observed on the online student portal - Investigate application/database logs; identify SQL Injection payloads in request parameters - Confirm unauthorized retrieval (exfiltration) of confidential student records - Assess the scope of the breach — affected records, systems, and severity
Containment	Reactive	- Temporarily disable/take the vulnerable application offline to stop further exploitation - Block malicious requests and attacker IP addresses through firewall/WAF rules - Restrict database access to only essential, trusted services during the incident
Eradication	Reactive	- Locate the vulnerable query/code path responsible for the SQL Injection - Remove any injected payloads, unauthorized accounts, or web shells left behind - Patch the application using parameterized queries/prepared statements and input validation
Recovery	Reactive	- Restore the database from a verified, clean backup taken prior to compromise - Bring the patched application back online in a controlled manner - Monitor traffic and logs closely for renewed or repeated attack attempts
Lessons Learned	Proactive	- Prepare a post-incident report and notify affected students per data-protection/compliance obligations - Improve the secure software development lifecycle (SDLC) with mandatory code reviews - Update WAF signatures/rules and schedule recurring penetration tests - Add automated static/dynamic application security testing (SAST/DAST) to the CI/CD pipeline

3. Comparative Observations

Both incidents follow the same six-phase NIST lifecycle, but differ in root cause and remediation focus:

- Case Study 1 centers on identity and access management failure (weak/exposed administrative access, brute-force login) and is remediated primarily through account and access hardening (MFA, IP restrictions, credential resets).
- Case Study 2 centers on an application-layer input validation flaw and is remediated primarily through secure coding practices (parameterized queries) and WAF/database access controls.
- In both cases, the Preparation and Lessons Learned phases are Proactive, while Detection & Analysis, Containment, Eradication, and Recovery are Reactive — reflecting the general pattern that the lifecycle begins and ends with risk-reduction activity, while the middle phases respond directly to the live incident.
- The 'Continuous Improvement Cycle' shown in each flowchart reflects NIST's guidance that Lessons Learned should feed back into Preparation, ensuring the organization is better positioned to prevent or respond to the next incident.